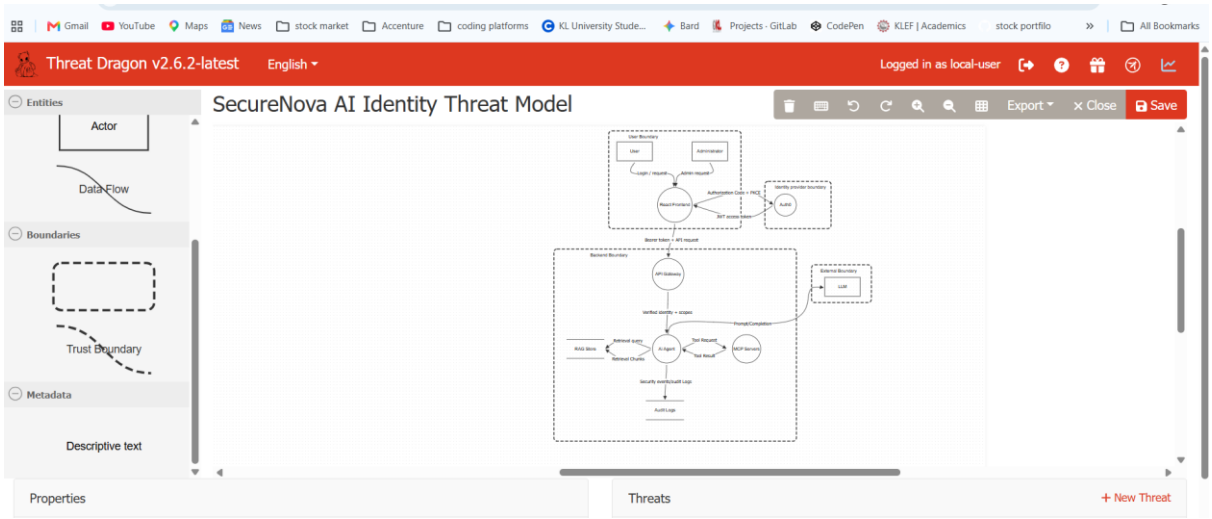
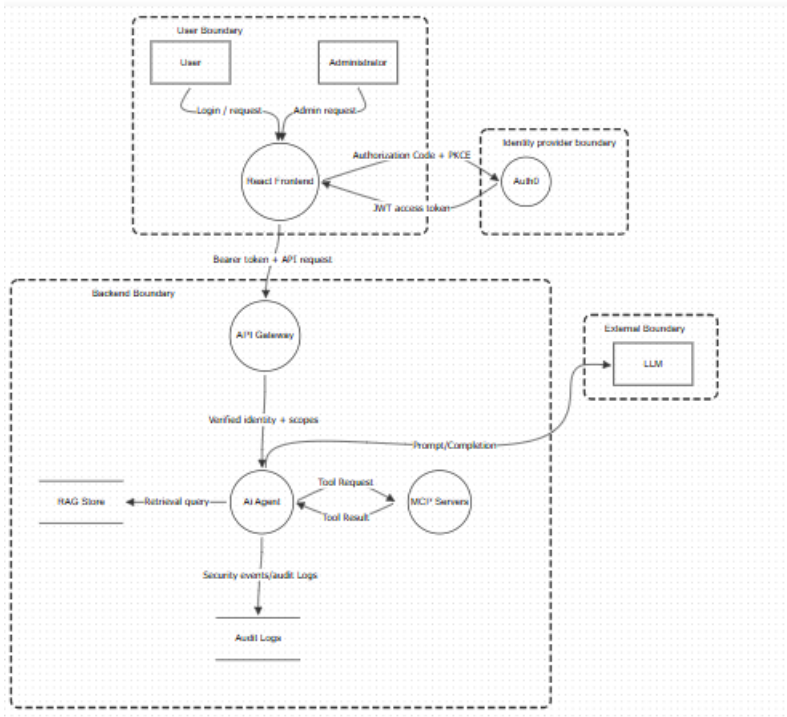
Project 1 - Threat Model the AI Identity System

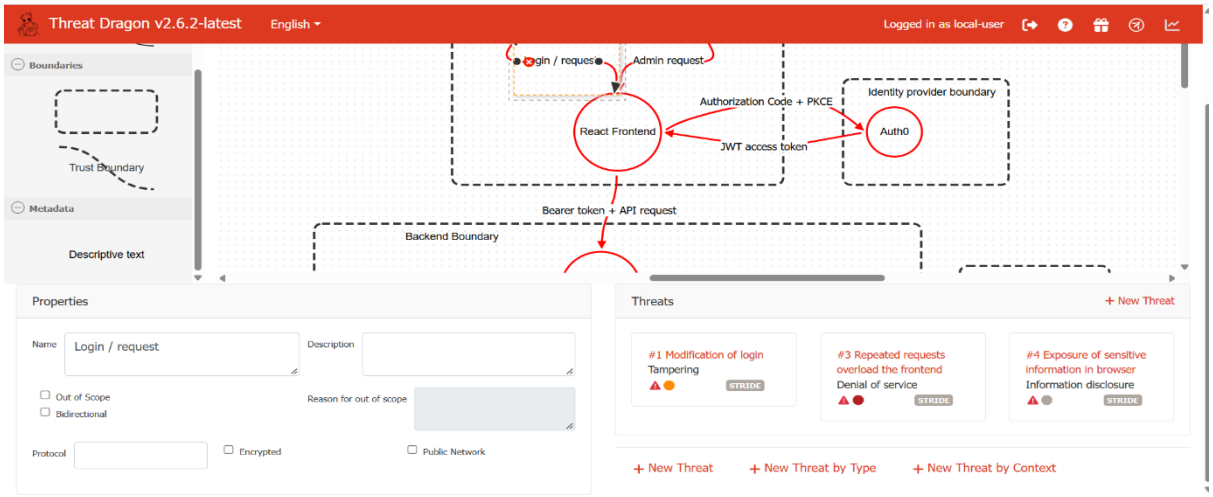
Threat Modelling:



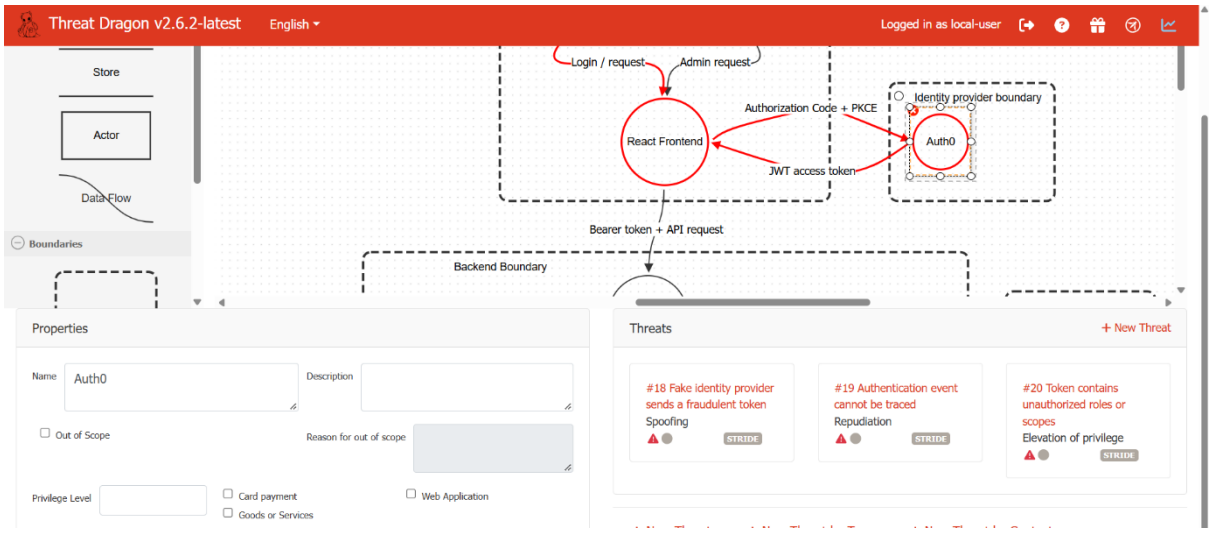


STRIDE threats:

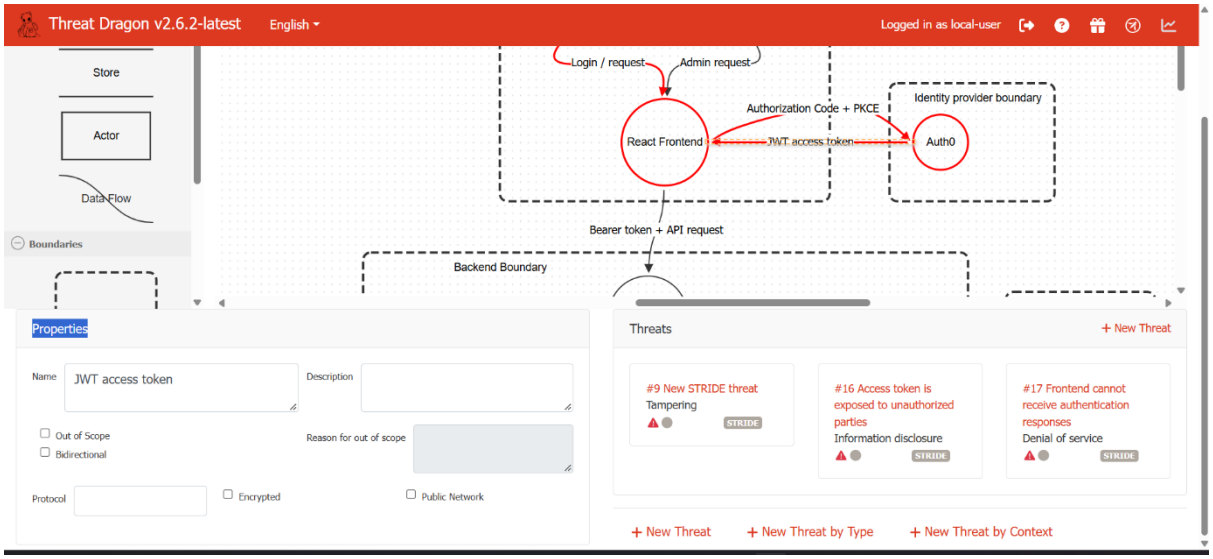
User login flow Threats:



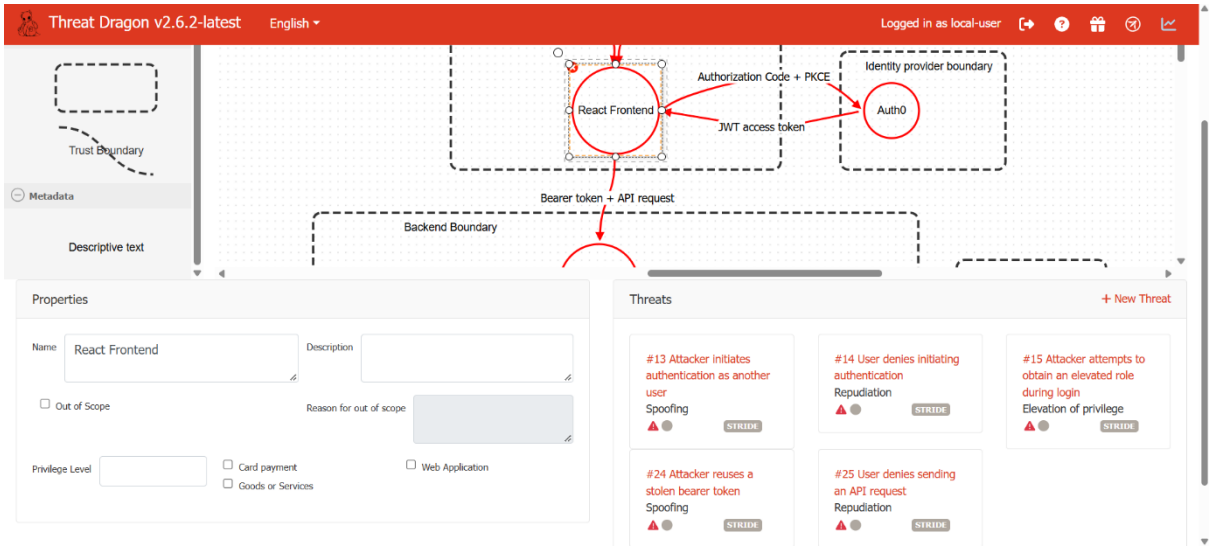
Auth0 flow threats:



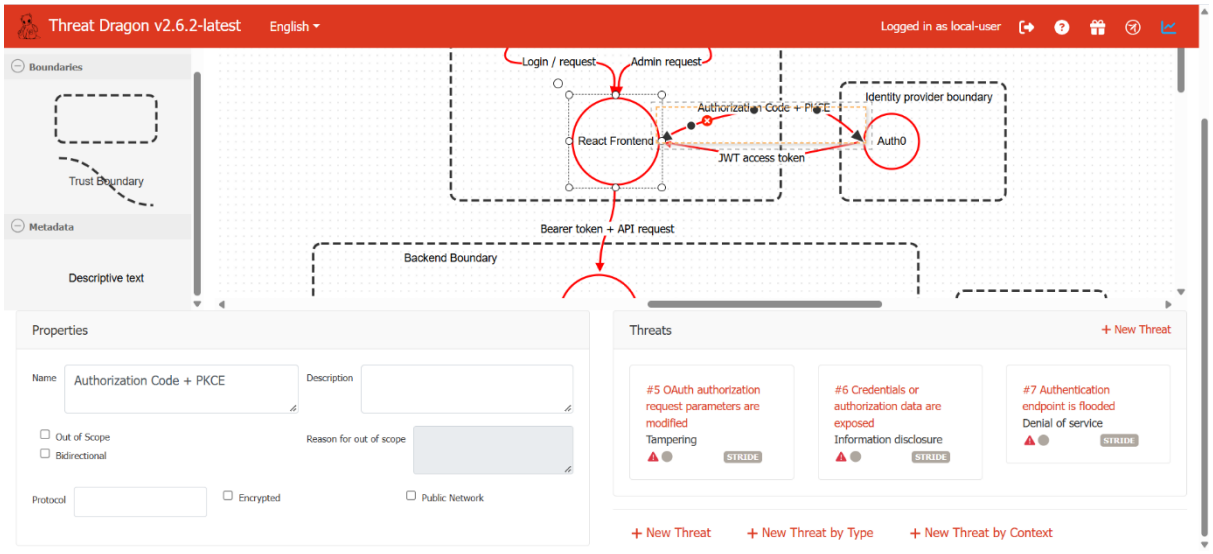
Auth0 to frontend flow Threats:



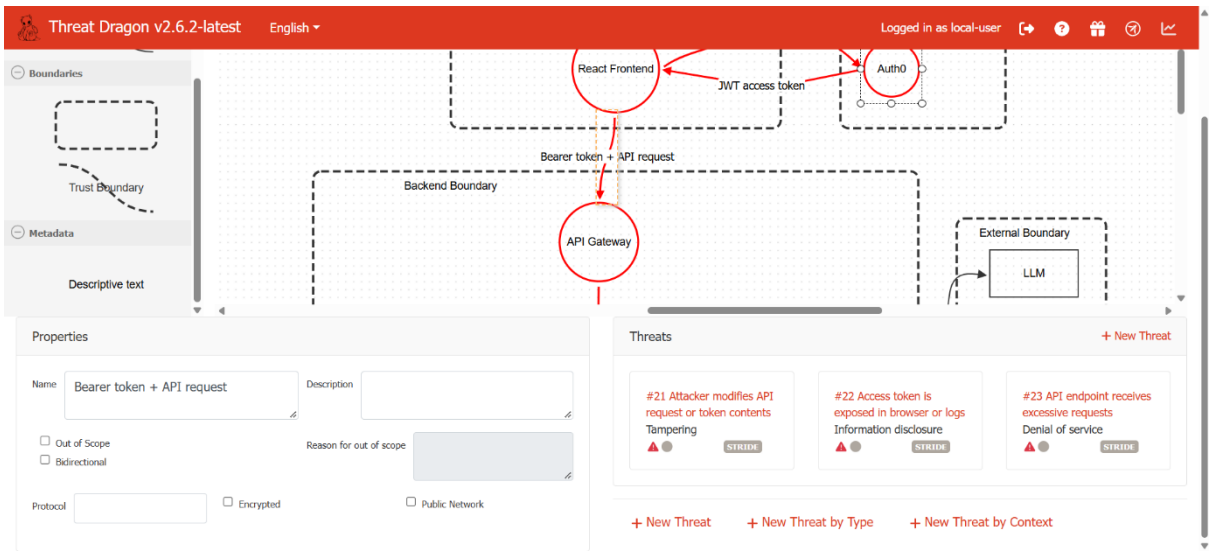
Frontend threats:



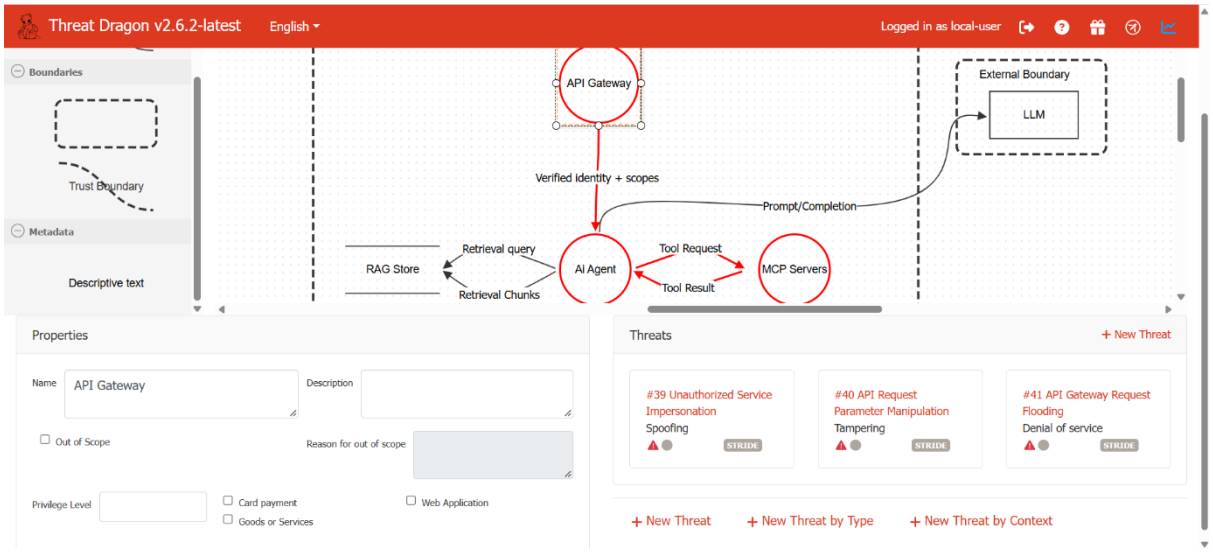
Frontend to Auth0 flow Threats:



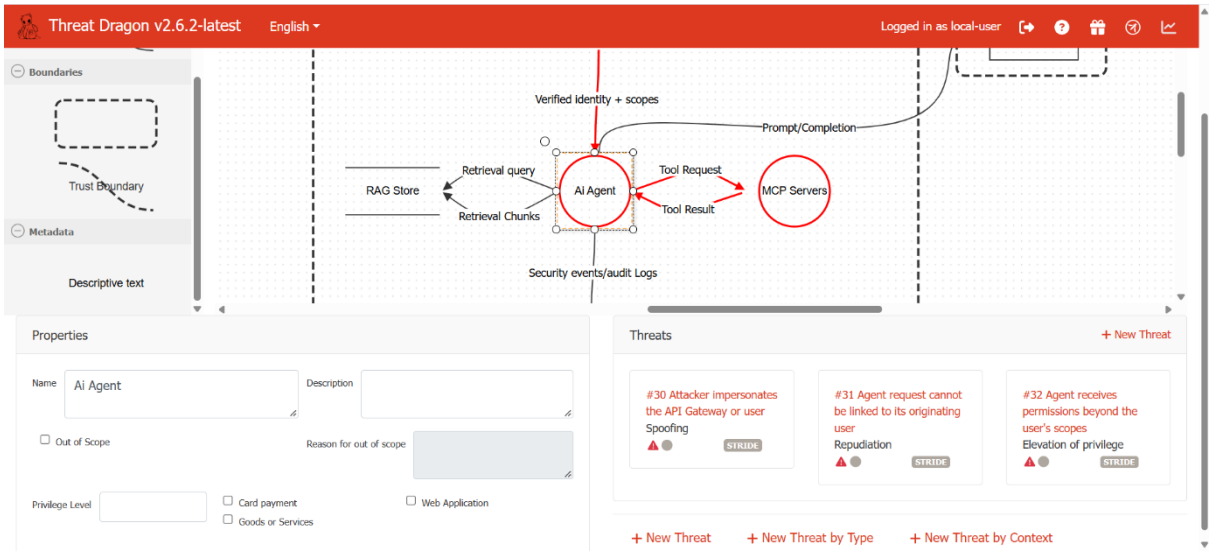
Frontend to Api Gateway Threats:



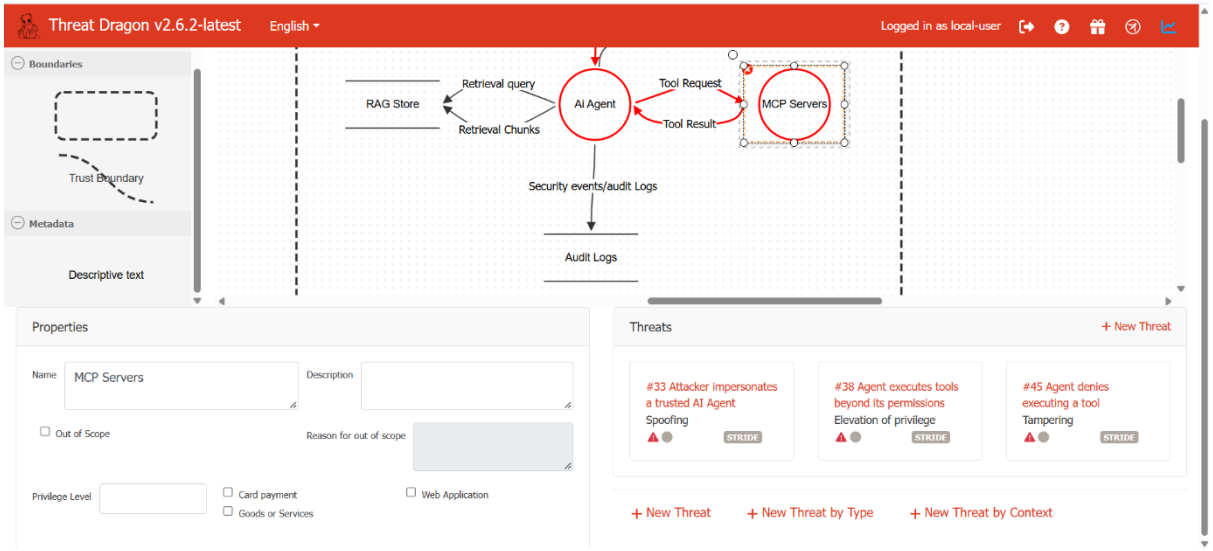
ApiGateway threats:



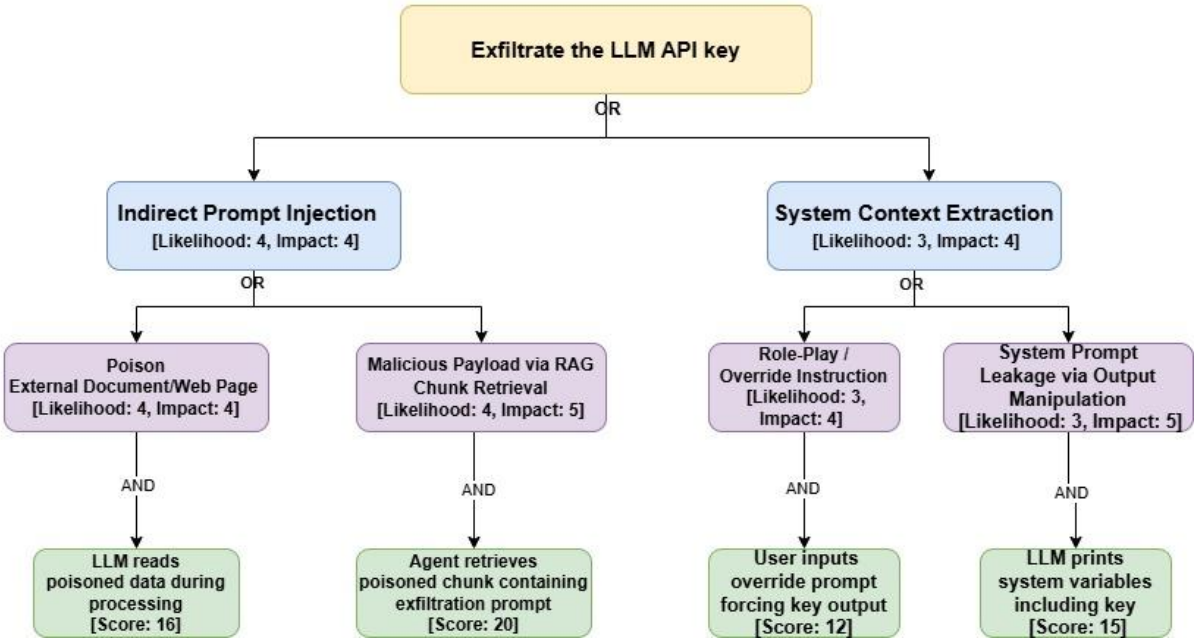
AI Agent Threats:



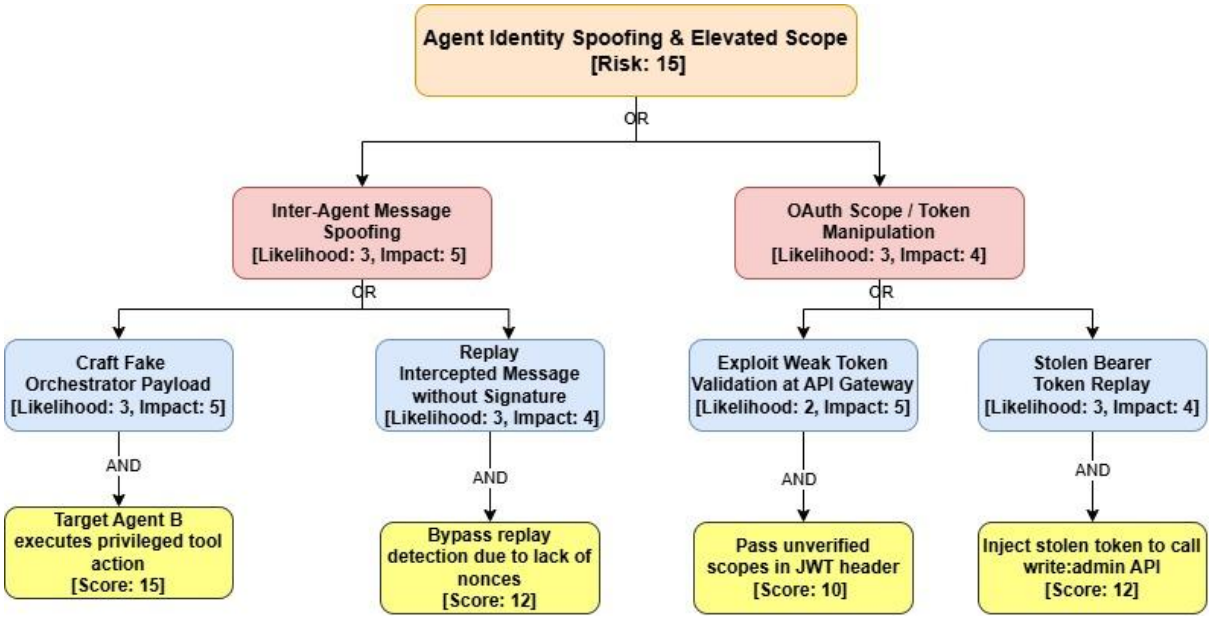
MCP Server Threat:



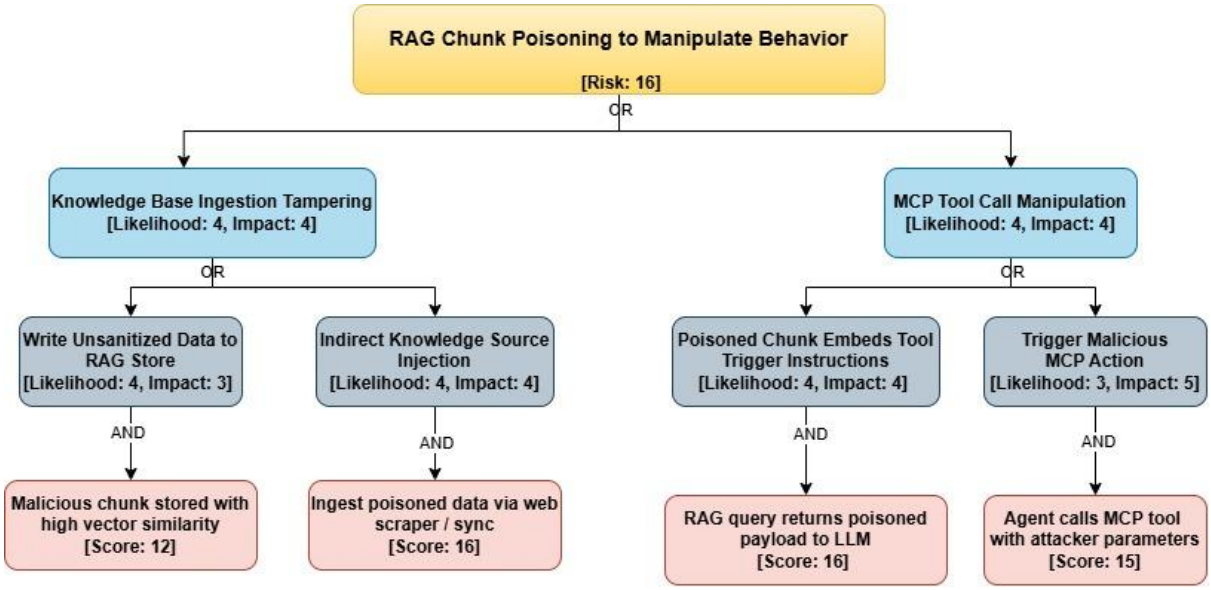
Attack Tree 1: LLM API Key Exfiltration via Prompt Injection



Attack Tree 2: Agent Identity Spoofing to Gain Elevated API Scope



Attack Tree 3: RAG Chunk Poisoning to Manipulate Agent Behavior



STRIDE Matrix

Threat ID	Component / flow	STRIDE category	Threat scenario	Security property affected	Recommended mitigation
S-01	User→ Auth0 / frontend	Spoofing	Attacker impersonates a customer using stolen credentials or session	Authentication	MFA; anomaly detection; session revocation; secure login
S-02	Agent → MCP server	Spoofing	Untrusted sender claims to be a trusted agent/orchestrator	Authentication / origin integrity	Ed25519 signature verification; trusted key registry; agent identity binding
T-01	Frontend → API Gateway	Tampering	JWT claims or request parameters are modified	Integrity	RS256 signature verification; issuer/audience/expiry checks; schema
T-02	RAG ingestion → vector store	Tampering	Malicious document or chunk changes retrieved context	Data integrity	Source allowlist; ingestion review; hashes; provenance; quarantine
R-01	Agent / MCP tool execution	Repudiation	A user or agent denies initiating a sensitive tool action	Accountability	Append-only audit logs with subject, agent_id, action, timestamp, request ID
R-02	Auth0 / API Gateway	Repudiation	Authentication and authorization decisions are not logged consistently	Accountability	Centralized logs; correlation IDs; synchronized clocks; retention
I-01	Agent → LLM provider	Information Disclosure	Prompt or response exposes API key or sensitive context	Confidentiality	Secret manager; least context; output redaction; no secrets in prompts/logs
I-02	Agent → RAG store	Information Disclosure	User retrieves another customer's restricted document	Confidentiality	Tenant-aware retrieval filters; document ACL enforcement; authorization before retrieval
D-01	Public login / API	Denial of Service	Repeated login or API requests exhaust capacity	Availability	Rate limiting; brute-force protection; quotas; alerting
D-02	LLM API / agent	Denial of Service	Unbounded prompts or tool loops create excessive model calls and cost	Availability / cost	Request limits; token budgets; timeouts; circuit breakers; monitoring
E-01	Customer API → admin API	Elevation of Privilege	Customer obtains administrative scope or invokes admin endpoint	Authorization	Least privilege; scope and role checks server-side; deny by default
E-02	AI Agent → MCP tools	Elevation of Privilege	Agent invokes a tool beyond its approved permissions	Authorization	Per-tool policy; action-level authorization; human approval for sensitive actions

Risk Register

Threat ID	Threat	Affected asset	STRIDE	CVSS 3.1 vector	CVSS score	Likelihood (1-5)	Impact (1-5)	Risk Score	Risk Rank	Risk Level
R-02	Forged agent identity accepted without signature validation	Agent-to-agent message	S	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N	9.1	4	5	20	1	Critical
R-03	JWT claim tampering or signature validation bypass	API Gateway	T	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N	9.1	4	5	20	1	Critical
R-07	Repeated requests exhaust AI service capacity	LLM API / backend	D	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H	7.5	4	5	20	1	Critical
R-01	Stolen customer session used to impersonate user	Auth0 session / customer account	S	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:L/A:N	7.1	4	4	16	4	High
R-04	RAG knowledge poisoning changes agent behavior	RAG store / AI agent	T	CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:H/A:L	8.2	4	4	16	4	High
R-08	Customer obtains admin permission through scope confusion	Admin API	E	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H	8.8	3	5	15	6	High
R-05	Sensitive data or API key disclosed in model output	LLM prompt / response	I	CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:N/A:N	6.8	3	4	12	7	High
R-09	Expired M2M token is accepted on replay	M2M API authentication	S	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N	8.1	3	4	12	7	High
R-10	Cross-tenant RAG retrieval returns another customer's data	RAG retrieval layer	I	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:N	7.7	3	4	12	7	High
R-06	Administrative action lacks reliable audit trail	MCP / admin operations	R	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N	4.3	2	3	6	10	Medium

LLM API Key Exfiltration via Prompt Injection MITRE ATLAS:

